

Authorization Layer

1. Overview:

Authentication verifies identity ("who are you?"), whereas authorization handles permission ("now that we know who you are, what can you actually see?"). Every time a team member clicks on a patient file, this system checks their credentials before serving any data.

- **Access Granted:** The file opens normally, and the event is recorded.
 - **Access Denied:** The record stays hidden, and the failed attempt triggers a security log entry.
-

2. The Core Model:

Relying on job titles alone is too broad, a single nurse shouldn't be able to open records for every patient across the entire hospital. Someone gets access only when all three conditions check out:

1. **Role:** Their job title (*Doctor, Nurse, Records Clerk, Lab Tech, IT*) dictates the baseline categories of information they can view.
2. **Ward / Department:** Where they are working during that shift (for instance, a Ward 3 nurse doesn't need eyes on Ward 7).
3. **Assignment:** Whether the patient is actively under their care (admitted to their ward, listed on their sheet, or referred to them).

Key Rule: All three factors must pass simultaneously, role or ward alone isn't enough.

3. Default Access Breakdown by Role:

Role	What They Can See	What Is Off-Limits
Doctor	Complete records for assigned/admitted patients (histories, clinical notes, test results, prescriptions).	Unassigned patients or patients outside their active ward.
Nurse	Vitals, active medications, and care notes for patients in their active ward/shift.	Complete diagnostic history or patients on other wards.
Lab Staff	Test orders and lab results currently in processing.	Clinical progress notes, medical history, or unrelated departments.
Records Clerk	Demographics and admin records (names, IDs, billing, appointment slots).	Clinical notes, medical diagnoses, or prescriptions.
Admin / IT	Account settings and operational system logs.	Patient clinical content, unless an explicit escalation path is triggered.

4. How Access Requests Are Evaluated:

When someone attempts to open a record, the system runs through these sequential checks:

1. **Authentication Check:** Is the user actively logged in with a valid session?
2. **Role Capability Check:** Does their job role permit access to this specific file type?
3. **Ward / Department Check:** Is the patient currently assigned to their department?
4. **Individual Assignment Check:** Is this specific user assigned to this patient right now?

Passing all four steps grants access; missing even one blocks the user, and both outcomes generate an audit record.

5. Emergency (Break Glass) Override:

When a critical emergency hits, clinicians can't be delayed by standard permission checks. The system includes a fast-track "Break Glass" mechanism:

- **Identity remains mandatory:** Users must still be logged into a valid account.
 - **Instant justification required:** The user must enter a brief reason on the spot (e.g., *"Code Blue, Ward 4"*).
 - **Flagged auditing:** Overrides stand out immediately in security audit feeds.
 - **Real-time monitoring:** Supervisors receive prompt alerts rather than burying events in passive log files.
-

6. Audit & Event Data Payload:

Every single request whether approved or blocked sends this payload straight to the logging engine:

- **Who:** User ID, active role, and ward assignment.
- **What:** Target Patient ID and specific record section requested.
- **Decision:** Granted vs. Denied, including which check step failed.
- **Access Type:** Standard request vs. Emergency Break Glass override.
- **Timestamp:** High-precision server timestamp.